

South Wootton Infant School, Audit Report**Audit Date: 4 March 2020****Report: Year 2 visit 2****DPE: Linda Mortimer****School members****Headteacher: Joanne Davenport****Business Manager: Sarah Crosby**

1. Visit details

Details highlighted at the time of the last visit were discussed. GDPR documents and policies were also reviewed. This included DPE Best Practice areas, Compliance Checklists, SLA tool, Record of Processing and Compliance Manager being discussed although these could not be demonstrated to the school as log in to Knowledge Bank was not accessible. The themed audit carried out by NCC in Summer Term 2019 was also talked through (refer to section 6 below) as well as when the need arises for completing a Data Protection Impact Assessment (DPIA), (refer to section 5.1 below).

Review actions recommended at time of previous visit – 1.10.19

There were no recommendations made at the time of the school walk on 1.10.19. The Headteacher asked for advice regarding birthday displays. However other recommendations were made at the time of the report and the majority have been actioned, however consideration should be given to:

Compliance Manager: Governors can be added to this facility which will enable the sharing of key documents. The school will add their GDPR Governor.

GDPR Policy: There is now a dedicated GDPR area on the website. School to amend policy to show that Data Protection Education is the named Data Protection Officer for the school.

Privacy Notice: Add a more detailed list of third parties with whom the school shares PII data. DPE suggest that this is in the form of a separate appendices to the Privacy Notice as this will enable easier amendments in the future. An example list will be provided by DPE.

Clear Desk and Screen Policy and Working Away from School: DPE recommends that these policies are adopted by the school and can be shared with all staff via the Compliance Manger.

Consent Forms: Following recent advice provided at DPE workshop, the school will update their consent form to reflect advice re PTA communication.

Document Retention: The school has been using Governor Hub's - Review of School Records and Safe Data Destruction Checklist. This is being present to the Governing Body this term.

Cyber Questionnaire: School to request again that their IT Technician completes the Cyber Questionnaire – this information will be required to facilitate the completion of the Record of Processing.

Audit walk and findings on 4.3.20

Management of SEND and Safeguarding Reports: All SEND and Safeguarding paperwork is retained in locked filing cabinet. Access to these documents is strictly controlled.

Management of Student Assessment: The school has not yet moved to CPOMS and continues to use hard copies which are retained in files and locked away at end of school day.

Management of Communication with Parent: The school uses Pupil Asset to provide communication to parents via text and email.

Publication Scheme: This was discussed and examples will be provided for the school to make reference to. More guidance can be found under the News tab on the Knowledge Bank.

Staff Training Update: The completion of staff training can be checked on the Dashboard in Knowledge Bank – go to Reports/Select Reports/Course Enrolment. A GDPR 20-minute refresher course will be available shortly on Knowledge Bank. DPE recommend that staff should refresh their training every 2 years.

Naming convention: All exercise books, work trays, files, display and coat pegs use first names only, birthday walls have been removed since the previous visit.

Staffroom: Pigeonholes were inspected and some sensitive paperwork was found ie list of staff emergency contact numbers and also staff names and DOB. Staff will be reminded of the risks of retaining information in such a way.

Safe Disposal of Documents: The school uses Restore Datashred, bags are kept in a locked cupboard until collection.

GDPR Self-Auditing: The school has an awareness of GDPR compliance and staff are reminded on a regular basis. The school will introduce a programme of self-auditing. Feedback on the outcome of these random walks will be provided to staff, therefore increasing the awareness of GDPR compliance.

School Kitchen: Operated by Norse. All allergy information is kept securely.

First Aid Records: Records are stored securely. The school queried the retention period for records relating to medicines administered by the school. The school will explore how they can scan parent permission slips for the administering of medicines and add to the student records on Pupil Asset. The retention guidelines for such permission slips was not evident in the IRMS Toolkit and DPE will investigate further and provide feedback to the school.

Medical Student Care Plans: Are stored securely in locked cupboard.

Password Policy: School will consider introducing a Password Policy and will review DPE model password policy. There is now bitesize Training now available on Knowledge Bank.

Year 1 Owl Classroom: Student progress files were removed from the general classroom area and relocated to a secure area in the classroom.

Year 2 Otters Classroom: A Teaching Assistant's folder containing general information about students was found in a work area. The folder also included details of student first names and surnames. The Headteacher confirmed that much of the information required shredding and will provide a reminder to staff to ensure that such information is stored securely.

Year 2 Red Squirrel Classroom: A 'Student Update' form detailing sensitive and personal information about a particular student was pinned to the wall in the TA's work area. Although initials were used, the student would have been easily identifiable from the observations made within the form. This information should be stored securely.

Reception Classroom / Quiet Room: Laptop left unlocked in empty room. Remind staff to lock computers when not in use / left unattended.

2. Compliance actions that should now be completed

Initial documents:

- Privacy Notice
- GDPR Policy
- Data Breach Procedure
- SAR procedure
- Photo and Video consent, guidelines and records

Ideally you would also have: Work away from school, clear desk and screen, information classification and record management policy/paperwork. Schools have either adopted the DPE models or incorporated some of this within their staff handbook, for example, work away from school.

The following should also be completed:

- There should be no named person on any of the above documents. If there is a named person i.e. Stuart Lee, the name needs replacing with: Data Protection Education Ltd;
- The Privacy Notice should have an appendix with your third-party suppliers listed. You should also make sure suppliers are GDPR compliant;
- The Privacy Notice, GDPR Policy and consent withdrawal form should be displayed on the school website;
- All staff should know what the data procedure is, and the document should be circulated to all staff;
- Key staff responding to SARs should have access to the SAR procedure and understand their responsibilities.

2.1. Data retention schedule:

By now you should be working through both physical and electronic data and have a good understanding of what data you hold and be documenting this. There are a number of documents available to support the process:

- Governor hub: annual review of school data and safe data destruction checklist
- DfE toolkit
https://assets.publishing.service.gov.uk/government/uploads/system/uploads/attachment_data/file/747620/Data_Protection_Toolkit_for_Schools_OpenBeta.pdf (Annex 5,1)

2.2. Staff training

GDPR training has been completed and documented for the majority of staff. If not already you should:

- Rollout training to key staff and then consider all staff completing the e-learning training;
- Add as part of the induction process for new staff;
- Use staff meetings/briefings to raise staff awareness.

2.3. Governance check

It should form part of governance that GDPR is an item at governor meetings and to share reports with governors. Ideally the governor responsible for GDPR will have completed some form of GDPR training.

2.4. Make sure DPE is your registered DPO with the ICO

Not only do you need to be registered as a controller with the ICO, it is a requirement to register who your DPO is. The guide to complete this is available from the News section of the DPE website: <https://kb.dataprotection.education/news-top/news/83-best-practice-updates/110-make-sure-dpe-is-your-registered-dpo-with-the-ico>

3. Freedom of Information and Publication Scheme

The DPE GDPR policy and FOI policy content refer to the organisation having a publication scheme - do you have one? **The template for a model publication scheme can be obtained from:** <https://ico.org.uk/media/for-organisations/documents/1235/definition-document-schools-in-england.pdf> How to complete a publication scheme guide can be obtained from: <https://ico.org.uk/media/for-organisations/documents/1242/how-to-complete-template-guide-to-info-for-schools.pdf> Additional guidance can be obtained from the news section of the DPE website: <https://kb.dataprotection.education/news-top/news>

4. Technical measures

DPE recommends schools complete the Cyber essentials questionnaire available from: DPE>Resources> Information Technology Security: <https://kb.dataprotection.education/best-practice-library/documents/information-technology-security/7-crest-cyber-essentials-questionnaire>;

Check iPad/Tablet security. Are all laptops encrypted, does your end of day routines include housekeeping to remove data no longer needed and is equipment secured? Do staff still use unencrypted memory sticks? DPE recommends schools develop procedures to ensure iPads can be accounted for daily and data (i.e photos) can be cleared if lost or stolen ([Erase your device](#))

5. Next steps

Record of Processing (RoP) tool and data mapping

DPE have started to populate the Record of Processing (RoP) tool. Rather than each school complete individually, DPE will be populating as many processes as possible and then work with you to complete for your school. It is a requirement under article 30 of the GDPR and will form part of the basis for future remote sessions and visits.

5.1. Data Protection Impact Assessments (DPIA)

When processing high risk personal data and using new technologies (i.e. moving to a new technology for Safeguarding) a DPIA should be completed and the DPO consulted (Article 35.2). DPIAs offer a risk assessment template where concerns can be noted alongside mitigating actions to reduce the overall risks related to change of practice. It is good practice to complete a DPIA for any major project where the processing of personal data is required. DPE will be providing more guidance, training and include risk management within the RoP tool. Always contact DPE in the first instance.

6. Norfolk County Council Summer GDPR audits

NCC auditors completed several themed GDPR audits during the summer term 2019. DPE have provided feedback to the findings which can be obtained from the News section of the DPE website: <https://kb.dataprotection.education/news-top/news>